SECURITY AWARENESS

Phishing Email Detection & Awareness Report

Employee Security Training & Phishing Analysis Guide

Prepared By: Purnendu Rai

Date: March 22, 2026

Classification: Security Awareness Document

Protect yourself. Protect your organization.

Think before you click.

Table of Contents

1. Executive Summary

2. Understanding Phishing

2.1 What is Phishing?

2.2 Types of Phishing Attacks

2.3 Why Phishing Works

3. Email Analysis Summary

4. Detailed Email Analysis

4.1 Phishing Emails (Critical/High Risk)

4.2 Suspicious Emails (Medium Risk)

4.3 Safe Emails (Low Risk)

5. Phishing Red Flags

6. Prevention Guidelines

6.1 Do's - Security Best Practices

6.2 Don'ts - Things to Avoid

7. Response Procedures

8. Conclusion

1. Executive Summary

Key Findings at a Glance

Phishing remains the most common and costly cyber threat facing organizations today. According to recent studies, **phishing accounts for over 90% of successful cyberattacks** and was the most reported crime type to the FBI in 2024 with 193,407 complaints.

6	4	1	10
Emails Analyzed	Phishing Detected	Critical Risk	Red Flags

This report analyzes **6 real-world email samples** to demonstrate how phishing attacks work and how to identify them. The analysis identified:

Classification	Count	Risk Level
Phishing	4	Critical/High - Immediate threat
Suspicious	1	Medium - Requires verification
Safe	1	Low - Legitimate communication

Most Dangerous Finding

Business Email Compromise (BEC) attacks pose the highest financial risk. In our analysis, EMAIL-004 demonstrates how attackers impersonate executives to request urgent wire transfers, bypassing normal approval processes. BEC attacks have caused **billions of dollars in losses globally**.

Key Takeaways

- **Always verify the sender** - Check email addresses carefully for typos
- **Hover before clicking** - See the actual URL destination
- **Be wary of urgency** - Phishing emails often create false pressure
- **Verify unusual requests** - Contact the sender through a trusted channel
- **When in doubt, don't click** - Report suspicious emails to IT security

2. Understanding Phishing

2.1 What is Phishing?

Phishing is a cyberattack where criminals send fake emails, text messages, or create fake websites that impersonate legitimate organizations. The goal is to trick recipients into:

- Revealing passwords and login credentials
- Providing financial information (credit cards, bank accounts)
- Downloading malware or ransomware
- Transferring money to attacker-controlled accounts
- Disclosing sensitive company information

Unlike technical exploits that target software vulnerabilities, **phishing targets human psychology**. Attackers exploit trust, fear, urgency, and curiosity to bypass natural skepticism.

2.2 Types of Phishing Attacks

Attack Type	Description	Target
Email Phishing	Mass emails impersonating banks, retailers, or services	General public
Spear Phishing	Targeted attacks using personal information about the victim	Specific individuals
Whaling	Attacks targeting executives and senior leaders	C-level executives

Business Email Compromise (BEC)	Impersonating executives to request wire transfers	Finance departments
Clone Phishing	Creating nearly identical copies of legitimate emails	Previous victims
Vishing	Voice phishing using phone calls	Phone users
Smishing	SMS/text message phishing	Mobile users

2.3 Why Phishing Works

Phishing attacks are successful because they exploit fundamental human traits:

Psychological Manipulation Tactics

- **Authority** - People tend to obey authority figures (CEO, IT admin, government)
- **Urgency** - Time pressure reduces critical thinking
- **Fear** - Threats of account closure, legal action, or financial loss
- **Curiosity** - "You've won!" or "Package delivery failed"
- **Trust** - Exploiting trust in well-known brands
- **Reciprocity** - "Free gift" creates obligation to respond

3. Email Analysis Summary

The following table summarizes all emails analyzed in this report:

ID	Subject	Sender	Classification	Risk
EMAIL-001	Urgent: Your Account Will Be Suspended	security@paypa1-secure.com	**PHISHING**	HIGH
EMAIL-002	Action Required: Password Expiration Notice	admin@microsoft365-security-update.com	**PHISHING**	HIGH

EMAIL-003	Invoice #INV-2026-0342 Payment Overdue	billing@amazon-business-invoice.com	**SUSPICIOUS**	MEDIUM
EMAIL-004	URGENT: Wire Transfer Request - Confidential	john.smith@company-executive.com	**PHISHING**	CRITICAL
EMAIL-005	Your Amazon Order Has Shipped	shipment-tracking@amazon.com	**SAFE**	LOW
EMAIL-006	You've Won a $500 Gift Card!	rewards@netflix-gift-center.com	**PHISHING**	HIGH

4. Detailed Email Analysis

4.1 Phishing Emails (Critical/High Risk)

EMAIL-001 PHISHING

Urgent: Your Account Will Be Suspended

From: PayPal Security Team <security@paypa1-secure.com> | Risk: HIGH

Attack Type: Credential Harvesting via Typosquatting

This email uses typosquatting - registering a domain that looks similar to PayPal (paypa1 with number 1 instead of letter l). The goal is to trick users into entering their PayPal credentials on a fake login page controlled by attackers.

Phishing Indicators Identified:

Suspicious Sender Domain HIGH

Domain 'paypa1-secure.com' uses number '1' instead of letter 'l' - classic typosquatting

Urgency Tactics MEDIUM

Uses fear-based language: 'account will be permanently suspended', '24 hours'

Suspicious Link HIGH

URL 'paypal-secure-verification.com' is not the official paypal.com domain

Generic Greeting LOW

Uses 'Dear Customer' instead of the recipient's actual name

Email Authentication HIGH

DKIM and SPF checks both FAILED

EMAIL-002 PHISHING

Action Required: Password Expiration Notice

From: Microsoft 365 Admin <admin@microsoft365-security-update.com> | Risk: HIGH

Attack Type: Corporate Credential Harvesting

This phishing email impersonates Microsoft 365 IT support, using the common fear of password expiration to trick employees into clicking a malicious link. The fake login page would harvest corporate credentials, potentially compromising the entire organization.

Phishing Indicators Identified:

Suspicious Sender Domain HIGH

Domain 'microsoft365-security-update.com' is not an official Microsoft domain

Urgency Tactics MEDIUM

Creates false urgency: 'password will expire in 24 hours', 'account lockout'

Suspicious Link HIGH

URL points to 'microsoft-365-login.secure-portal.net' - not microsoft.com

Email Authentication HIGH

No DKIM signature, SPF check FAILED

EMAIL-004 PHISHING

URGENT: Wire Transfer Request - Confidential

From: CEO John Smith <john.smith@company-executive.com> | Risk: CRITICAL

Attack Type: Business Email Compromise (BEC) / Whaling

This is a Business Email Compromise (BEC) attack - the most financially damaging type of phishing. The attacker impersonates the CEO to request an urgent wire transfer, bypassing normal approval processes. BEC attacks have caused billions in losses globally. The 'Sent from my iPhone' signature adds plausibility for the brief, urgent message.

Phishing Indicators Identified:

Suspicious Sender Domain CRITICAL

Domain 'company-executive.com' is not the company's actual domain

Authority Abuse CRITICAL

Impersonates CEO using authority to bypass normal procedures

Unusual Request CRITICAL

Requests large wire transfer ($47,500) without proper documentation or approval chain

Extreme Urgency HIGH

Multiple urgency indicators: 'URGENT', 'time-sensitive', 'must be completed today'

Email Authentication HIGH

No DKIM, SPF FAILED - email is not properly authenticated

EMAIL-006 PHISHING

You've Won a $500 Gift Card!

From: Netflix Rewards <rewards@netflix-gift-center.com> | Risk: HIGH

Attack Type: Prize/Lottery Scam

This is a classic "too good to be true" scam. Victims are lured by the promise of a free gift card and tricked into clicking a link that either harvests credentials or installs malware. The urgency ('48 hours') pressures victims to act without thinking.

Phishing Indicators Identified:

Too Good To Be True HIGH
Promises free $500 gift card - unrealistic offer you didn't enter or earn

Suspicious Sender Domain HIGH
Domain 'netflix-gift-center.com' is not an official Netflix domain

Urgency Tactics MEDIUM
Creates false scarcity: 'expires in 48 hours'

Email Authentication HIGH
DKIM and SPF checks both FAILED

4.2 Suspicious Emails (Medium Risk)

EMAIL-003 SUSPICIOUS

Invoice #INV-2026-0342 Payment Overdue

From: Amazon Business <billing@amazon-business-invoice.com> | Risk: MEDIUM

Attack Type: Potential Invoice Fraud / Payment Diversion

This email shows characteristics of invoice fraud. While it has some authentication (DKIM passed), the domain is suspicious and the payment link doesn't use Amazon's official domain. Requires verification before any action.

Suspicious Indicators:

Suspicious Domain MEDIUM

Domain 'amazon-business-invoice.com' is suspicious - Amazon uses amazon.com

Partial Authentication MEDIUM

DKIM passed but SPF softfail - partially authenticated

Suspicious Link MEDIUM

Payment URL does not use official amazon.com domain

Recommended Action:

Verify before paying. Contact Amazon Business directly through their official website or known phone number. Do not use contact information from this email.

4.3 Safe Emails (Low Risk)

EMAIL-005 SAFE

Your Amazon Order #112-3456789-1234567 Has Shipped

From: Amazon.com <shipment-tracking@amazon.com> | Risk: LOW

Classification: Legitimate Email

This is a legitimate shipping notification from Amazon. All authentication checks pass, links point to official domains, and the content is consistent with standard Amazon communications.

Safety Indicators:

Verified Sender Domain SAFE
Domain 'amazon.com' is the official Amazon domain

Proper Authentication SAFE
DKIM, SPF, and DMARC all PASSED

Verified Links SAFE
Links point to official amazon.com domain

5. Phishing Red Flags

Use this checklist to identify phishing emails. Answering "yes" to any question is a warning sign:

Red Flag	What to Look For	Example
Suspicious Sender Domain	Typosquatting, extra words, or unrelated domains	security@paypa1-secure.com vs service@paypal.com

Urgency & Fear Tactics	Pressure to act immediately with threats	"Your account will be suspended in 24 hours"
Generic Greetings	"Dear Customer" instead of your name	"Dear Valued Customer" vs "Dear John Smith"
Suspicious Links	URLs that don't match the claimed sender	Link shows PayPal but reveals scam-site.com
Unexpected Attachments	Files you didn't request, especially .exe, .zip	Invoice_0342.zip from unknown sender
Requests for Sensitive Info	Asking for passwords, PINs, or full SSN	"Please confirm your password to continue"
Too Good To Be True	Prizes, lottery wins, inheritances	"You've won a $500 gift card! Click to claim"
Poor Grammar/Spelling	Professional companies proofread communications	"We noticed suspicious activitys on your account"
Unusual Executive Requests	CEO asking to bypass normal procedures	Urgent wire transfer without documentation
Auth Failures	Missing or failed DKIM, SPF, DMARC	Email from 'amazon.com' that fails SPF

6. Prevention Guidelines

6.1 Do's - Security Best Practices

1. Verify the sender's email address carefully - look for typos and suspicious domains
2. Hover over links before clicking to see the actual URL destination
3. Check for email authentication (DKIM, SPF, DMARC) when available

4. Contact the sender through a known, trusted channel to verify suspicious requests
5. Report phishing emails to your IT security team immediately
6. Use multi-factor authentication (MFA) on all accounts
7. Keep software and security tools updated
8. Verify urgent requests through a second channel (phone call, in-person)
9. Check for your name in the greeting - legitimate companies personalize emails
10. Look for poor grammar, spelling errors, and awkward phrasing

6.2 Don'ts - Things to Avoid

1. Don't click on links or download attachments from unknown senders
2. Don't enter credentials on websites accessed through email links
3. Don't trust emails that create urgency or use fear tactics
4. Don't reply to suspicious emails - this confirms your email is active
5. Don't assume official-looking logos mean the email is legitimate
6. Don't provide sensitive information (passwords, SSN, financial data) via email
7. Don't bypass security protocols even when requested by 'executives'
8. Don't trust 'too good to be true' offers (free prizes, lottery wins)

> **9.** Don't open password-protected attachments unless you requested them

> **10.** Don't scan QR codes in unexpected emails

7. Response Procedures

If You Suspect a Phishing Email:

1. **STOP** - Do not click any links or download attachments
2. **VERIFY** - Contact the sender through a trusted channel (not using email reply)
3. **REPORT** - Forward the email to your IT security team
4. **DELETE** - Remove the email from your inbox
5. **MONITOR** - Watch your accounts for any suspicious activity

If You Clicked a Suspicious Link:

1. **DISCONNECT** - Disconnect from the internet immediately
2. **SCAN** - Run a full antivirus scan on your device
3. **CHANGE PASSWORDS** - Change passwords for any accounts that may be compromised
4. **REPORT** - Notify your IT security team immediately
5. **MONITOR** - Watch for unauthorized activity on your accounts

Reporting Phishing:

- **Internal:** Forward to your IT security team or security@company.com
- **US Government:** Report to reportphishing@apwg.org and reportfraud.ftc.gov
- **Email Provider:** Use the "Report phishing" button in your email client
- **Impersonated Company:** Forward to the security team of the impersonated company

8. Conclusion

Phishing attacks continue to be the most prevalent and successful form of cyberattack because they target the weakest link in security: **people**. Technical security measures alone cannot protect against well-crafted

phishing emails that exploit human psychology.

Key Takeaways

- **Think before you click** - Take time to examine emails carefully
- **Verify independently** - Use trusted channels to confirm suspicious requests
- **When in doubt, report it** - It's better to report a false positive than fall for a real attack
- **Stay informed** - Phishing tactics evolve; keep learning about new threats
- **Use available tools** - Enable MFA, keep software updated, use email security features

Remember

> *"The best defense against phishing is an educated and vigilant user. Your security awareness is the most powerful tool in protecting yourself and your organization."*

References

- FBI Internet Crime Complaint Center (IC3) - https://www.ic3.gov
- Anti-Phishing Working Group (APWG) - https://apwg.org
- CISA Phishing Guidance - https://www.cisa.gov/phishing
- FTC Report Fraud - https://reportfraud.ftc.gov
- Google Email Header Analyzer - https://toolbox.googleapps.com/apps/messageheader/